Microsoft 365 Copilot Data Governance & DLP Guardrails

Implementation Solution Guide

Version 1.0.0 · 2026-07-09

Contents

Executive Summary — Microsoft 365 Copilot Data Governance & DLP Guardrails 4
- What this is . . . 4
- The outcome . . . 4
- The boundary . . . 4
- Effort . . . 4
- What is delivered . . . 5

1. Solution Overview — Microsoft 365 Copilot Data Governance & DLP Guardrails 5
- What it is . . . 5
- How the technology works . . . 5
- The standard deployment model — Assess → Configure → Pilot → Validate → Expand . . . 6
- Scope . . . 6
- What is out of scope . . . 6
- Authentication & connections used . . . 7

2. Requirements — Microsoft 365 Copilot Data Governance & DLP Guardrails 7
- 2.1 Microsoft Purview information-protection & DLP licensing — verify . . . 7
- 2.2 Compliance / Information Protection roles . . . 8
- 2.3 PowerShell — Security & Compliance PowerShell and Microsoft Graph . . . 8
- 2.4 Published sensitivity-label taxonomy (baseline) . . . 8
- 2.5 Auditing enabled (Copilot interactions) . . . 8
- 2.6 Defined pilot ring and simulation window . . . 9
- 2.7 Compliance-stakeholder engagement (classification determinations) . . . 9
- 2.8 Responsible-use / acceptable-AI-use policy (referenced) . . . 9

Global Requirements — Copilot (category-level) 9
- G1. Microsoft 365 tenant with supported workloads . . . 10
- G2. Microsoft 365 Copilot licensing . . . 10
- G3. Microsoft Entra ID identity and MFA . . . 10
- G4. Data readiness — permissions & oversharing controls . . . 10
- G5. Information protection baseline (sensitivity labels) . . . 10
- G6. Administrative roles . . . 10
- G7. Network and client readiness . . . 11
- G8. Governance & responsible-use policy . . . 11

3. Implementation Guide — Microsoft 365 Copilot Data Governance & DLP Guardrails 11
- Objects you will create (naming reference) . . . 11
- Step 0 — Confirm scope, licensing, roles, and connections (Assess) . . . 12
- Step 1 — Discover label coverage & sensitive content (Assess) . . . 12

Step 2 — Design the controls with compliance stakeholders (Configure) . . . 13
Step 3 — Configure & pilot labeling (Configure → Pilot) . . . 13
Step 4 — Configure & pilot DLP for Copilot (Configure → Pilot) . . . 13
Step 5 — Configure prompt/response guardrails & audit (Configure → Pilot) . . . 14
Step 6 — Validate the pilot (Validate) . . . 14
Step 7 — Expand, enforce, and record the governance evidence (Expand) . . . 14
5. Testing & Validation — Microsoft 365 Copilot Data Governance & DLP Guardrails 15
Test 1 — Scope, licensing & connections (Step 0) . . . 15
Test 2 — Label coverage discovered (Step 1) . . . 15
Test 3 — Control design recorded (Step 2) . . . 15
Test 4 — Labeling piloted safely (Step 3) . . . 16
Test 5 — DLP for Copilot in test only (Step 4) . . . 16
Test 6 — Audit & eDiscovery capture Copilot interactions (Step 5) — decisive . . . 16
Test 7 — Simulation/test false-positive review (Step 6) — decisive . . . 16
Test 8 — Enforce, evidence & recurring review (Step 7) . . . 17
Evidence to retain . . . 17
6. Troubleshooting — Microsoft 365 Copilot Data Governance & DLP Guardrails 17
Cannot connect Security & Compliance PowerShell . . . 17
The Microsoft 365 Copilot DLP location is not offered . . . 17
Discovery shows no labels / no sensitive info types . . . 18
Auto-labeling policy created but it labelled content immediately . . . 18
DLP-for-Copilot test policy is blocking Copilot in the pilot . . . 18
No Copilot interaction events in the audit search . . . 18
Simulation shows too many false positives . . . 18
Copilot still uses content you expected the label to keep out . . . 19
Enforcement change didn't take effect . . . 19
eDiscovery can't find Copilot interactions . . . 19
7. Best Practices — Microsoft 365 Copilot Data Governance & DLP Guardrails 19
Keep it clean . . . 19
Where to go next (adjacent catalog areas) . . . 20
8. Deliverables Summary — Microsoft 365 Copilot Data Governance & DLP Guardrails 21
Documentation (8 guides) . . . 21
PowerShell scripts (5) . . . 22
How it is delivered . . . 22
Boundaries recap . . . 23
Appendix A — PowerShell Scripts 24

Executive Summary — Microsoft 365 Copilot Data Governance & DLP Guardrails

What this is

A self-guided, field-tested playbook that governs **what Microsoft 365 Copilot is allowed to use and produce**. Once Copilot is live, the risk shifts from *access* to *governance*: which content can be reasoned over, which sensitive data must stay out of AI responses, and how every prompt and response is audited. This solution applies **sensitivity labels** to Copilot-accessible content, configures **Data Loss Prevention (DLP) for Microsoft 365 Copilot** to keep labelled/sensitive data out of AI processing, adds guardrails around prompt and response handling, and makes Copilot interactions **auditable and eDiscovery-ready** — all **piloted in simulation before any block is enforced**.

The outcome

- **A label-coverage picture** of the Copilot-accessible estate — where sensitive content is labelled, and where it is not.
- **Sensitivity-label alignment** so the right content carries the right label (with encryption / usage rights where warranted, which Copilot honors at item level).
- **DLP for Microsoft 365 Copilot** scoped to the Copilot location and conditioned on the agreed "keep out of Copilot" labels/sensitive-info-types — **built in simulation/test first**.
- **Prompt/response guardrails** and an **audit + eDiscovery** path for Copilot interactions.
- **Proof it works** — simulation results reviewed for false positives, then a staged move to enforce, with a governance report for sign-off.

The boundary

This solution governs **what Copilot can use and produce** via Purview labels, DLP, and audit. It is the information-protection counterpart to the Copilot oversharing/SharePoint-permissions solution (which fixes *access*), and it references — rather than duplicates — the Purview label-taxonomy and DLP program solutions. **DLP for Microsoft 365 Copilot and several related controls are licensing-dependent and some capabilities are in preview — availability is flagged "verify," never assumed. Classification determinations** — what counts as "sensitive," what is acceptable for AI to process, and which content must be blocked — are **deferred to the customer's compliance, records, privacy, and legal functions**; this package supplies the technical controls and the evidence, not the classification verdicts.

Effort

A competent M365/Purview administrator can run the **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** model in roughly **2–5 working days** for a pilot ring, then repeat per wave. Discovery, validation, and audit search are automated with read-only PowerShell (Microsoft Graph / Security & Compliance PowerShell); every enforcing control is created in **simulation/test** and validated before enforcement.

What is delivered

Eight guides (this summary, overview, requirements, implementation, testing, troubleshooting, best practices, deliverables) and **five safe-by-default PowerShell scripts** (read-only discovery, validation, audit search, reporting; `-WhatIf`/simulation-gated guardrails) — all white-label, no secrets in code, delivered as a Complete Solution Package (PDF + Word + scripts).

1. Solution Overview — Microsoft 365 Copilot Data Governance & DLP Guardrails

What it is

A repeatable method to **govern the data boundary around Microsoft 365 Copilot** using Microsoft Purview: sensitivity labels on Copilot-accessible content, **DLP for Microsoft 365 Copilot** to restrict labelled or sensitive data from AI processing, guardrails on how prompts and responses are handled, and audit / eDiscovery of Copilot interactions. Where the oversharing/SharePoint-permissions solution fixes *who can reach what*, this solution governs *what Copilot is allowed to use and generate* — and it is built **simulation-first** so nothing is blocked until it has been validated.

How the technology works

• **Copilot honors information protection.** Sensitivity labels with **encryption / usage rights** are enforced at the item level — Copilot will not surface or summarize content a user cannot decrypt. Labels are therefore the primary governance lever, not just a classification tag.

• **DLP for Microsoft 365 Copilot** is a Data Loss Prevention location scoped to the **Copilot** experience: a policy conditioned on sensitivity labels (or sensitive information types) can keep the matching content **out of Copilot responses**. *(The Copilot DLP location and some behaviors are licensing-gated and/or in preview — verify current availability in your tenant.)*

• **Auto-labeling** closes label-coverage gaps at scale by applying a label when content matches agreed conditions — run in **simulation** first to size the impact before it labels anything.

• **Prompt / response guardrails** combine the above with organizational responsible-use policy: what Copilot may process, what it must exclude, and how generated content is handled.

• **Audit & eDiscovery.** Copilot prompts and responses are recorded in the **Purview unified audit log** and are discoverable via **eDiscovery** — the evidence trail for governance and investigations.

• **Automation** is PowerShell: **Security & Compliance PowerShell** (`Connect-IPPSSession`) for labels, auto-labeling, and DLP; **Microsoft Graph** for coverage discovery and audit queries; the **Purview portal** for the policy blades.

The standard deployment model — Assess → Configure → Pilot → Validate → Expand

1. **Assess** — confirm scope, licensing (including DLP-for-Copilot availability), roles, connections; run read-only discovery for label coverage and sensitive content across the Copilot-accessible estate.

1. **Configure** — with compliance stakeholders, agree the default label, the "keep out of Copilot" labels/conditions, and the guardrails; stage the label policy, auto-labeling, and DLP-for-Copilot in **simulation/test**.

1. **Pilot** — publish to a **pilot ring**; auto-labeling in **simulation** (labels nothing yet), DLP-for-Copilot in **test/disabled** (blocks nothing yet).

1. **Validate** — review simulation/test matches for false positives; confirm audit/eDiscovery captures Copilot interactions; confirm no legitimate Copilot use is over-blocked.

1. **Expand** — only after the gate passes, move auto-labeling to **on** and DLP-for-Copilot to **enforce**, widen scope under change control, record the governance report, and stand up a recurring review.

Scope

- Label-coverage discovery across the Copilot-accessible estate; sensitive-content picture.
- Sensitivity-label alignment (default labeling, auto-labeling in simulation) so Copilot-accessible content is correctly classified.
- DLP for Microsoft 365 Copilot to restrict labelled/sensitive data from AI processing — simulation-first.
- Prompt/response guardrails tied to responsible-use policy.
- Audit + eDiscovery of Copilot interactions.

What is out of scope

- **Classification determinations** — what is "sensitive," acceptable for AI, or must be blocked — are the compliance/legal/records decision; this guide supplies the technical controls and evidence.
- **Designing the full sensitivity-label taxonomy and the broad DLP program** (endpoint/cloud/email) — delivered in the Purview information-protection and DLP solutions; referenced, not rebuilt, here.
- **Fixing SharePoint/OneDrive oversharing (access)** — delivered in the Copilot oversharing/SharePoint-permissions solution; this solution governs *use*, that one governs *access*.
- **Copilot licensing/enablement, identity, network/client readiness** — covered by the Copilot global requirements and the Entra solutions.

Authentication & connections used

• **Security & Compliance PowerShell** (`Connect-IPPSSession`) — labels, auto-labeling, DLP policies.

• **Microsoft Graph PowerShell** (`Connect-MgGraph`, read scopes e.g. `AuditLog.Read.All`, `InformationProtectionPolicy.Read`) — coverage discovery and audit queries.

• **Microsoft Purview portal** (`https://purview.microsoft.com`) — Information Protection, DLP, Audit,

and eDiscovery blades.

• **Roles:** Compliance Administrator / Compliance Data Administrator (or scoped Information Protection and

DLP roles), and eDiscovery Manager for the audit/eDiscovery path. Reserve Global Administrator for tenant-wide changes only.

> *The category-level prerequisites (tenant, Copilot licensing, Entra identity/MFA, admin roles, network/client readiness, governance policy) live in* `global-requirements-copilot.md` *— confirm those first; this solution's specific prerequisites are in doc 2.*

2. Requirements — Microsoft 365 Copilot Data Governance & DLP Guardrails

The category-level prerequisites (Microsoft 365 tenant and workloads, Copilot licensing, Entra ID identity/MFA, administrative roles, network/client readiness, and governance/responsible-use policy) are covered once in `global-requirements-copilot.md` — confirm those first and do not repeat them here. Below are the prerequisites **specific to this data-governance/DLP solution**. Each: **Description / Why required / How to verify / How to implement if missing.**

2.1 Microsoft Purview information-protection & DLP licensing — verify

• **Description:** The Purview plan that unlocks sensitivity labels, auto-labeling, and DLP (commonly

E5 / E5 Compliance or equivalent), plus the **DLP for Microsoft 365 Copilot** capability.

• **Why required:** Labeling, auto-labeling, and DLP-for-Copilot are the core controls; some are

plan-gated and some are in preview.

• **How to verify:** Purview portal → **Information Protection** and **Data Loss Prevention** render and

allow policy creation; confirm the **Microsoft 365 Copilot** location is offered when creating a DLP policy. *(DLP-for-Copilot availability/behavior is licensing-dependent and may be in preview — verify in your tenant.)*

• **How to implement if missing:** Acquire the required Purview plan; where DLP-for-Copilot is not

present, govern via label **encryption/usage rights** (honored by Copilot) as the interim equivalent and note DLP-for-Copilot as pending.

2.2 Compliance / Information Protection roles

• **Description:** Compliance Administrator / Compliance Data Administrator (or scoped Information Protection Admin and DLP Compliance roles), and eDiscovery Manager for the audit/eDiscovery path.

• **Why required:** Creating labels, auto-labeling, and DLP policies and running eDiscovery require these roles.

• **How to verify:** Purview portal → **Roles & scopes** (or Entra **Roles and administrators**) shows the operator holds them.

• **How to implement if missing:** Assign least-privilege compliance roles for the task; reserve Global Administrator for tenant-wide changes.

2.3 PowerShell — Security & Compliance PowerShell and Microsoft Graph

• **Description:** The Exchange Online management module (for `Connect-IPPSSession`) and `Microsoft.Graph` installed on the operator workstation.

• **Why required:** The bundled scripts manage labels/auto-labeling/DLP via Security & Compliance PowerShell and query coverage/audit via Graph.

• **How to verify:** `Get-Module ExchangeOnlineManagement,Microsoft.Graph -ListAvailable`; the discovery script reports which are present.

• **How to implement if missing:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` and `Install-Module Microsoft.Graph -Scope CurrentUser`. PowerShell 7+ recommended.

2.4 Published sensitivity-label taxonomy (baseline)

• **Description:** A published sensitivity-label set in Purview (even minimal), ideally with a defined "highly confidential / do-not-use-in-AI" tier.

• **Why required:** DLP-for-Copilot and default/auto-labeling condition on labels; without a taxonomy there is nothing to enforce against.

• **How to verify:** Purview portal → **Information Protection** → **Labels** shows published labels.

• **How to implement if missing:** Publish a baseline taxonomy first (see the Purview information-protection / sensitivity-label solutions). This solution *applies and enforces* labels around Copilot; it does not design the taxonomy.

2.5 Auditing enabled (Copilot interactions)

• **Description:** Purview unified audit logging enabled so Copilot prompts/responses are recorded.

• **Why required:** The audit/eDiscovery guardrail and the validation evidence depend on the audit trail.

• **How to verify:** Purview portal → **Audit** shows recording is on; `Search-UnifiedAuditLog` returns Copilot interaction events.

• **How to implement if missing:** Enable auditing (**Audit** → *Start recording user and admin activity*); allow time for backfill before relying on it.

2.6 Defined pilot ring and simulation window

• **Description:** A **pilot ring** of users for the label policy and DLP-for-Copilot, and an agreed **simulation/test window** before enforcement.

• **Why required:** Every enforcing control is piloted in simulation/test first; you must know the pilot population and how long simulation runs before you evaluate.

• **How to verify:** A documented pilot user group and a recorded simulation window.

• **How to implement if missing:** Define the pilot cohort (e.g. the Copilot pilot users) and agree the window (commonly aligned to a review cadence) with stakeholders.

2.7 Compliance-stakeholder engagement (classification determinations)

• **Description:** Named compliance/records/privacy/legal stakeholders who own the classification and acceptable-AI-use determinations.

• **Why required:** *What is "sensitive," acceptable for AI, or must be blocked* is their decision, not the admin's; the technical controls implement their determinations.

• **How to verify:** Stakeholders identified and available for the design step; determinations recorded.

• **How to implement if missing:** Engage them before Configure; do not invent classification rules — record their decisions and implement them.

2.8 Responsible-use / acceptable-AI-use policy (referenced)

• **Description:** An organizational position on acceptable Copilot use and data handling (from the category governance requirement).

• **Why required:** The prompt/response guardrails operationalize this policy; without it, "acceptable" is undefined.

• **How to verify:** A documented AI-use policy exists (global requirement G8).

• **How to implement if missing:** Adopt the policy (a compliance/legal determination) and map its rules to the technical guardrails here.

Global Requirements — Copilot (category-level)

These requirements apply to every solution in the Copilot category. They are published once at the category level so individual listings stay small. Confirm these before deploying any Microsoft 365 Copilot solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *Copilot inherits the tenant's existing identity, permission, and data-governance posture. It creates no new access — but it surfaces everything a user already has. Treat data readiness (oversharing, labeling) as a prerequisite, not an afterthought, and pilot before broad enablement.*

G1. Microsoft 365 tenant with supported workloads

Description: A Microsoft 365 tenant with Exchange Online, SharePoint Online, OneDrive, and Teams in use. Why: Copilot reasons over Microsoft Graph content across these workloads; they must be provisioned and healthy. Verify: Microsoft 365 admin center shows the services active; users have mailboxes and OneDrive provisioned. Implement: Provision/enable the M365 workloads and confirm users are licensed for them before adding Copilot.

G2. Microsoft 365 Copilot licensing

Description: Microsoft 365 Copilot licenses for the target users (a prerequisite base M365 plan applies). Why: Copilot is a per-user add-on; a user cannot use Copilot without an assigned license on a qualifying base plan. Verify: Admin center -> `Billing -> Licenses`; confirm Copilot licenses and free seats. *Verify current base-plan prerequisites in your tenant.* Implement: Purchase/assign Microsoft 365 Copilot licenses to the pilot cohort; assign via group where possible.

G3. Microsoft Entra ID identity and MFA

Description: Cloud identities in Entra ID with MFA and healthy sign-in. Why: Copilot honors identity and Conditional Access; a weak or broken identity plane undermines both access and security. Verify: Users sign in at `https://entra.microsoft.com` resources; MFA is enforced for the cohort. Implement: Ensure licensed, MFA-protected Entra accounts (see the Entra category solutions for identity hardening).

G4. Data readiness — permissions & oversharing controls

Description: A known state of SharePoint/OneDrive permissions and sharing (no unmanaged broad access). Why: Copilot can surface any content the user has access to; oversharing becomes AI data exposure. Verify: Review sharing reports / SharePoint Advanced Management signals; run the solution's discovery script. *SAM/Restricted Content Discovery availability varies — verify in your tenant.* Implement: Remediate broad-access sites and links before broad Copilot enablement (see the oversharing-remediation solution).

G5. Information protection baseline (sensitivity labels)

Description: A published sensitivity-label taxonomy (even minimal) in Microsoft Purview. Why: Labels are how you keep sensitive content out of AI processing where required and audit what Copilot uses. Verify: Purview compliance portal -> Information Protection shows published labels. Implement: Publish a baseline label set (see the Purview information-protection solutions) before enforcing AI guardrails.

G6. Administrative roles

Description: Global Administrator (or scoped admin roles: SharePoint Admin, Security/Compliance Admin) for the operator. Why: Enabling Copilot, remediating SharePoint, and configuring Purview DLP/labels require these roles. Verify: Entra -> `Roles and administrators`; confirm the required roles. Implement: Assign least-privilege roles for the task; reserve Global Administrator for tenant-wide changes.

G7. Network and client readiness

Description: Supported Microsoft 365 Apps clients and network access to Microsoft 365/Copilot endpoints. Why: Copilot experiences in Word/Excel/Outlook/Teams require current clients and connectivity. Verify: Clients on a supported channel/build; Microsoft 365 endpoints reachable. *Verify current client requirements.* Implement: Update the M365 Apps channel/build and allow the required endpoints.

G8. Governance & responsible-use policy

Description: An organizational position on acceptable AI use, data handling, and auditability. Why: Copilot generates and surfaces content; the organization must define what is acceptable and keep an audit trail. Verify: A documented AI-use/acceptable-use policy exists; Copilot interactions are auditable (Purview audit). Implement: Adopt an AI-use policy; enable audit/eDiscovery for Copilot. *Governance and acceptable-use determinations are the customer's compliance/legal decision — this guide covers the technical controls only.*

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Microsoft 365 Copilot Data Governance & DLP Guardrails

Follow these steps **in order**. Discovery, validation, audit search, and reporting are automated with read-only PowerShell (Microsoft Graph / Security & Compliance PowerShell); the guardrail policies are created in the **Microsoft Purview portal** (`https://purview.microsoft.com`) and/or the bundled `CPLTGOV-Guardrails.ps1`, which **defaults to `-WhatIf`/simulation** — nothing enforces without an explicit `-Commit` and a passed pilot gate. Every object you create follows the `<Purpose> – <Scope> – <Stage>` convention and is reused verbatim in Testing, Troubleshooting, and the scripts.

> ***Model:*** *confirm scope → discover label coverage and sensitive content → design the controls with compliance stakeholders → configure and* ***pilot in simulation/test*** *→ validate for false positives and audit capture → expand to enforce, record the governance report, review on a cadence. Pattern:* ***Assess → Configure → Pilot (simulate/test) → Validate → Expand (enforce). Portal-path caveat.*** *Purview blades evolve and several controls (DLP for Copilot especially) are licensing-gated or in preview. The paths below are the current map; if a blade, location, or cmdlet differs in your tenant, use the closest documented equivalent and* ***confirm before acting*** *— never assume a path that is not present.*

Objects you will create (naming reference)

Object	Name	Where
Label-coverage inventory	`Copilot Label Coverage – Estate – Assess`	`CPLTGOV-Discovery.ps1`
Default label policy	`Default Labeling – Users – Pilot`	Purview / `CPLTGOV-Guardrails.ps1`
Auto-labeling (simulation)	`Auto-Label Sensitive – Pilot – Simulation`	Purview / `CPLTGOV-Guardrails.ps1`
DLP for Copilot (test)	`DLP for Copilot – Pilot – Test`	Purview / `CPLTGOV-Guardrails.ps1`
Copilot audit evidence	`Copilot Interaction Audit – Tenant – Validate`	`CPLTGOV-AuditSearch.ps1`
Governance evidence	`Copilot Governance Report – Tenant – Expand`	`CPLTGOV-Report.ps1`
Recurring cadence tag	`Copilot Governance Review – Tenant – Recurring`	scheduled script chain

Step 0 — Confirm scope, licensing, roles, and connections (Assess)

1. On the operator workstation, sign in for read-only work:

• `Connect-IPPSSession` (Security & Compliance PowerShell).

• `Connect-MgGraph -Scopes "AuditLog.Read.All","InformationProtectionPolicy.Read"` (Graph).

1. Run `CPLTGOV-Discovery.ps1 -ScopeOnly` (read-only). It confirms the sign-ins, enumerates the licensing-dependent levers available (labels, label policies, DLP policies, auto-labeling policies), checks whether the **Copilot DLP location** is offered, and confirms **auditing** is on (Requirements 2.1–2.5). Note anything absent so you scope around it.

1. Confirm the **pilot ring** and the **simulation window** (Requirement 2.6) and that compliance stakeholders are engaged (Requirement 2.7) before any configuration.

Pass/fail: Sign-ins succeed, levers enumerated, Copilot DLP location availability known, auditing on, pilot ring and window agreed. **Rollback:** None — read-only.

Step 1 — Discover label coverage & sensitive content (Assess)

1. Run `CPLTGOV-Discovery.ps1` (read-only). It reports the published **labels** and **sensitive information types**, **and the** label-coverage** picture for the Copilot-accessible estate — which in-scope locations have little or no labeling — writing `Copilot Label Coverage – Estate – Assess`.

1. Where **DSPM for AI** is present, cross-read its data-access and sensitive-interactions views as corroborating telemetry — this solution *governs* what those views reveal.

1. Rank: locations with **unlabeled sensitive content** that Copilot can reach are the priority for

labeling and for the "keep out of Copilot" DLP condition.

Pass/fail: The coverage export is written; the top unlabeled-sensitive locations can be named. **Rollback:** None — read-only.

Step 2 — Design the controls with compliance stakeholders (Configure)

1. With compliance/records/privacy/legal stakeholders (Requirement 2.7), agree, for the pilot ring:

(a) the **default label** to apply; whether **mandatory labeling** is in scope; (b) which labels denote "**keep out of Copilot**" and therefore drive DLP-for-Copilot; (c) the **auto-labeling** conditions (which sensitive info types → which label); and (d) the **prompt/response guardrails** derived from the responsible-use policy (Requirement 2.8).

1. **Record this as the design baseline.** *The determinations (what is "sensitive," acceptable exposure,

what must be blocked) are the stakeholders'* — you provide the method and will implement and pilot the agreed technical controls.

Pass/fail: The agreed control set and "keep out of Copilot" label list are recorded. **Rollback:** None — design only.

Step 3 — Configure & pilot labeling (Configure → Pilot)

1. **Default labeling (pilot).** In the Purview portal → **Information Protection** → **Label policies**,

publish a policy scoped to the **pilot ring** that sets a **default label** (and mandatory labeling if agreed). Name it `Default Labeling – Users – Pilot`. *(Mandatory labeling availability is licensing-dependent — verify.)*

1. **Auto-labeling (simulation).** Run

`CPLTGOV-Guardrails.ps1 -Action AutoLabel -Name "Auto-Label Sensitive – Pilot – Simulation"` (defaults to `-WhatIf`; add `-Commit` to create it). With `-Commit` it creates the auto-labeling policy in **simulation mode** — it labels *nothing* yet; it only shows what it *would* label against the agreed conditions, sizing the coverage gap without risk.

Pass/fail: The pilot label policy is published to the ring; the auto-labeling policy exists in **simulation** (labels nothing yet). **Rollback:** Unpublish the label policy; delete the simulation auto-labeling policy — no content was changed.

Step 4 — Configure & pilot DLP for Copilot (Configure → Pilot)

1. Run `CPLTGOV-Guardrails.ps1 -Action DlpForCopilot -Name "DLP for Copilot – Pilot – Test"` with

`-Commit` to create the DLP policy `DLP for Copilot – Pilot – Test` in **test/disabled** mode, scoped to the **Microsoft 365 Copilot** location and conditioned on the agreed "keep out of Copilot" sensitivity labels — so Copilot will not process/summarize that content **once enforced**.

1. **Verify the Copilot DLP location name in your portal** — the script parameterizes the location and

does not assume it, because the Copilot DLP location is evolving/licensing-gated *(verify)*. If the location is not present in your tenant, keep the "keep out of Copilot" content controlled via label **encryption/usage**

rights (which Copilot honors) and note DLP-for-Copilot as pending.

Pass/fail: The DLP-for-Copilot policy exists in **test/disabled** on the Copilot location — nothing is enforced yet. **Rollback:** Delete the test policy; no interaction was blocked.

Step 5 — Configure prompt/response guardrails & audit (Configure → Pilot)

1. **Guardrails.** Map the responsible-use policy to the technical controls: the "keep out of Copilot"

labels (Step 4) plus any content-exclusion via labels/encryption define what Copilot may *use*; capture the agreed handling of generated content (e.g. labeling of Copilot outputs where supported) as part of the design baseline.

1. **Audit & eDiscovery.** Confirm Copilot interactions are recorded: run `CPLTGOV-AuditSearch.ps1`

(read-only) to retrieve recent **Copilot interaction** audit events into `Copilot Interaction Audit – Tenant – Validate`, and confirm they are discoverable via **eDiscovery** (Purview portal → **eDiscovery**). This is the evidence trail the guardrails rely on.

Pass/fail: Guardrail mapping recorded; Copilot interaction audit events retrievable and eDiscoverable. **Rollback:** None — read-only for the audit path.

Step 6 — Validate the pilot (Validate)

1. Let simulation/test run the agreed window. In the portal review the auto-labeling **simulation

results **(what it would label) and the DLP-for-Copilot** test **matches (what it would keep out of Copilot) for** false positives**.

1. Run `CPLTGOV-Validate.ps1` (read-only). It confirms the pilot label policy is published, the

auto-labeling policy is in **simulation**, the DLP-for-Copilot policy is in **test/disabled**, and auditing is on. It writes a validation summary.

1. Confirm with stakeholders that the simulated outcomes match intent (no legitimate Copilot use

over-blocked, sensitive content correctly matched). See Testing (doc 5) for the explicit gates.

Pass/fail: Simulation/test reviewed, acceptable false-positive rate, audit capture confirmed. **Rollback:** If results are wrong, adjust the policy conditions and re-pilot — enforce nothing until the gate passes.

Step 7 — Expand, enforce, and record the governance evidence (Expand)

1. Only after the pilot gate passes: turn the auto-labeling policy from **simulation** to **on**, and the

DLP-for-Copilot policy from **test** to **enforce**, and widen the label policy beyond the pilot ring — as a deliberate, change-controlled step. `CPLTGOV-Guardrails.ps1 -Action Enforce -Commit` performs the mode change on the named policies (still gated behind `-Commit`).

1. Run `CPLTGOV-Report.ps1` (read-only) to compile the **governance evidence record**

`Copilot Governance Report – Tenant – Expand` — label coverage before/after, the controls applied and their state, the audit-capture confirmation, and the residual risk — for stakeholder sign-off. **The classification and acceptable-use determinations remain the stakeholders'**; the report is the evidence.

1. Stand up the recurring review: tag the cadence `Copilot Governance Review – Tenant – Recurring` and

schedule the read-only `Discovery` → `AuditSearch` → `Validate` → `Report` chain (e.g. monthly) so governance stays measured as data, labels, and Copilot usage change.

Pass/fail: Controls enforced at agreed scope, coverage improved on re-measure, governance report compiled and signed off, recurring review scheduled. **Rollback:** Return any enforced policy to simulation/test (or delete it) if enforcement causes an issue; the discovery and report exports are the before-state to restore toward.

5. Testing & Validation — Microsoft 365 Copilot Data Governance & DLP Guardrails

Validate the build against explicit **pass/fail gates** before enforcing anything. Discovery, validation, audit search, and reporting are automated and read-only; the enforcing controls are created in simulation/test and evaluated for false positives first. Record each result against the named object.

> ***Principle:*** *the pilot gate is a* ***simulation/test review with an acceptable false-positive rate****, plus* ***confirmed audit capture*** *of Copilot interactions — with* ***no legitimate Copilot use over-blocked****. Nothing moves to enforce until every gate below passes.*

Test 1 — Scope, licensing & connections (Step 0)

- **Procedure:** Run `CPLTGOV-Discovery.ps1 -ScopeOnly`.
- **Pass:** `Connect-IPPSSession` / `Connect-MgGraph` succeed; labels/label-policies/DLP/auto-labeling

levers enumerated; the **Copilot DLP location** availability is reported; auditing is on; pilot ring and simulation window agreed.

- **Fail:** A sign-in fails, or the Copilot DLP location is absent → resolve (Requirements 2.1–2.5); if

DLP-for-Copilot is unavailable, plan the label-encryption interim and note it pending.

Test 2 — Label coverage discovered (Step 1)

- **Procedure:** Run `CPLTGOV-Discovery.ps1`; open `Copilot Label Coverage – Estate – Assess`.
- **Pass:** The export lists published labels, sensitive info types, and the coverage picture; the top

unlabeled-sensitive locations Copilot can reach are named.

- **Fail:** Empty/partial → confirm `Connect-IPPSSession` and read scopes; re-run.

Test 3 — Control design recorded (Step 2)

- **Procedure:** Review the design baseline.
- **Pass:** The default label, the "keep out of Copilot" labels, the auto-labeling conditions, and the

prompt/response guardrails are recorded, with stakeholder ownership of the classification determinations noted.

• **Fail:** Any determination is an admin guess rather than a stakeholder decision → engage compliance (Requirement 2.7) before configuring.

Test 4 — Labeling piloted safely (Step 3)

• **Procedure:** Confirm `Default Labeling – Users – Pilot` is published to the ring; run `CPLTGOV-Guardrails.ps1 -Action AutoLabel -Name "Auto-Label Sensitive – Pilot – Simulation" -WhatIf` then, after review, `-Commit`.

• **Pass:** The label policy applies to the pilot ring only; the auto-labeling policy exists in **simulation** and has labelled **nothing** yet.

• **Fail:** Auto-labeling created outside simulation → delete and recreate in simulation; never label content before the simulation review.

Test 5 — DLP for Copilot in test only (Step 4)

• **Procedure:** Confirm `DLP for Copilot – Pilot – Test` exists via the portal / `CPLTGOV-Validate.ps1`.

• **Pass:** The policy is scoped to the **Microsoft 365 Copilot** location, conditioned on the agreed labels, and is in **test/disabled** — it blocks **nothing** yet.

• **Fail:** The policy is enabled/enforcing, or scoped to the wrong location → set to test/disabled and re-scope; verify the Copilot location name in your tenant.

Test 6 — Audit & eDiscovery capture Copilot interactions (Step 5) — decisive

• **Procedure:** Generate a few Copilot prompts/responses in the pilot ring, then run `CPLTGOV-AuditSearch.ps1` and check `Copilot Interaction Audit – Tenant – Validate`; confirm the events are discoverable in **eDiscovery**.

• **Pass:** Copilot interaction events appear in the audit search and are eDiscoverable — the evidence trail works.

• **Fail:** No events → confirm auditing is on (Requirement 2.5), allow for backfill latency, and re-run.

Test 7 — Simulation/test false-positive review (Step 6) — decisive

• **Procedure:** After the simulation window, review the auto-labeling **simulation results** and the DLP-for-Copilot **test** matches with stakeholders.

• **Pass:** The matches are accurate (sensitive content correctly identified); the false-positive rate is acceptable to stakeholders; no legitimate Copilot use would be over-blocked.

• **Fail:** Too many false positives / legitimate use blocked → tune the conditions and re-pilot; do not enforce.

Test 8 — Enforce, evidence & recurring review (Step 7)

• **Procedure:** After the gate passes, move auto-labeling to **on** and DLP-for-Copilot to **enforce** (`CPLTGOV-Guardrails.ps1 -Action Enforce -Commit`); run `CPLTGOV-Report.ps1`; confirm the `Copilot Governance Review – Tenant – Recurring` chain is scheduled.

• **Pass:** Policies enforced at the agreed scope; `Copilot Governance Report – Tenant – Expand` shows the before/after coverage, controls and their state, audit capture, and residual risk; the read-only review chain is scheduled.

• **Fail:** Enforcement causes an issue → return the affected policy to simulation/test and re-tune.

Evidence to retain

• `Copilot Label Coverage – Estate – Assess` (baseline) and the post-enforcement re-measure.

• The simulation/test review notes (false-positive assessment, stakeholder sign-off).

• `Copilot Interaction Audit – Tenant – Validate` (audit-capture confirmation).

• `Copilot Governance Report – Tenant – Expand` (the governance sign-off record).

• The recorded classification/acceptable-use determinations from Step 2 (the stakeholders' decisions).

6. Troubleshooting — Microsoft 365 Copilot Data Governance & DLP Guardrails

Common failures, their cause, and the fix. Symptoms map to the implementation steps.

Cannot connect Security & Compliance PowerShell

• **Symptom:** `Connect-IPPSSession` fails or cmdlets like `Get-Label` are not found.

• **Cause:** Missing/old `ExchangeOnlineManagement` module, or insufficient role.

• **Fix:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (or `Update-Module`); reconnect; confirm a Compliance/Information Protection role (Requirement 2.2). PowerShell 7+ recommended.

The Microsoft 365 Copilot DLP location is not offered

• **Symptom:** Creating a DLP policy shows no **Microsoft 365 Copilot** location.

• **Cause:** DLP-for-Copilot is licensing-gated and/or in preview and not enabled in your tenant.

(Verify current availability.)

- **Fix:** Confirm the required Purview plan; where the location is genuinely unavailable, govern the

"keep out of Copilot" content via label **encryption/usage rights** (honored by Copilot) as the interim control and note DLP-for-Copilot as pending. `CPLTGOV-Guardrails.ps1` parameterizes the location and will warn rather than assume it.

Discovery shows no labels / no sensitive info types

- **Symptom:** `Copilot Label Coverage – Estate – Assess` lists no labels or SITs.
- **Cause:** No published label taxonomy yet, or the session lacks read access.
- **Fix:** Publish a baseline taxonomy first (Requirement 2.4 / the Purview information-protection

solutions); reconnect `Connect-IPPSSession`; re-run. This solution enforces labels; it does not design the taxonomy.

Auto-labeling policy created but it labelled content immediately

- **Symptom:** Content got labelled before the simulation review.
- **Cause:** The policy was created in **on** mode rather than simulation.
- **Fix:** Recreate in **simulation** (`CPLTGOV-Guardrails.ps1 -Action AutoLabel` defaults to a

simulation/`-WhatIf` posture). Simulation labels nothing — it only shows what it *would* label. Review first, enforce later.

DLP-for-Copilot test policy is blocking Copilot in the pilot

- **Symptom:** Copilot won't process content for pilot users during the test window.
- **Cause:** The policy was set to enforce rather than **test/disabled**, or the condition is too broad.
- **Fix:** Set the policy back to **test/disabled** (`CPLTGOV-Validate.ps1` confirms mode); tune the label/

SIT condition; only move to enforce after the false-positive review passes (Testing Test 7).

No Copilot interaction events in the audit search

- **Symptom:** `CPLTGOV-AuditSearch.ps1` returns nothing for the pilot users.
- **Cause 1 — auditing off/recently enabled: Fix:** Enable Purview **Audit**; allow backfill time;

re-run.

- **Cause 2 — latency:** Audit events can lag the interaction. **Fix:** Wait and re-run; widen the time

window and confirm the correct operation/record types for Copilot in your tenant *(verify)*.

- **Cause 3 — scope/role: Fix:** Confirm `AuditLog.Read.All` (Graph) or the audit-search role.

Simulation shows too many false positives

- **Symptom:** Auto-labeling or DLP-for-Copilot would match far more than intended.

• **Cause:** The condition (sensitive info type / label) is too broad, or confidence/instance thresholds are loose.

• **Fix:** Narrow the sensitive-info-type set, raise confidence/instance-count thresholds, tighten the "keep out of Copilot" label list, and re-run the simulation. Keep the highly-confidential tier small.

Copilot still uses content you expected the label to keep out

• **Symptom:** After labeling, Copilot still surfaces the content.

• **Cause 1:** The label has no **encryption/usage rights** — a visual-marking-only label does not stop Copilot from reading the content. **Fix:** Apply a label configured with encryption/usage rights for the do-not-use-in-AI tier.

• **Cause 2:** DLP-for-Copilot is still in **test** (not enforcing). **Fix:** Complete the pilot gate and move to enforce.

• **Cause 3 — indexing latency: Fix:** Allow time for the label/DLP change to propagate; re-test and record the time.

Enforcement change didn't take effect

• **Symptom:** After `CPLTGOV-Guardrails.ps1 -Action Enforce -Commit`, policies still show simulation/test.

• **Cause:** `-Commit` omitted, wrong policy name, or insufficient role.

• **Fix:** Re-run with `-Commit` and the exact object names (`Auto-Label Sensitive – Pilot – Simulation`, `DLP for Copilot – Pilot – Test`); confirm the compliance role; verify in the portal.

eDiscovery can't find Copilot interactions

• **Symptom:** An eDiscovery search returns no Copilot prompts/responses.

• **Cause:** Auditing off during the period, wrong search scope, or eDiscovery role missing.

• **Fix:** Confirm auditing was on for the period, use the correct location/scope, and confirm the **eDiscovery Manager** role (Requirement 2.2).

7. Best Practices — Microsoft 365 Copilot Data Governance & DLP Guardrails

Keep the Copilot data boundary governed over time, and know where to go next in the catalog.

Keep it clean

• **Simulate before you enforce, always.** Auto-labeling starts in **simulation**, DLP-for-Copilot starts

in **test/disabled**. Review the matches for false positives, then move to enforce — never enable a block that hasn't been evaluated against real content.

• **Let compliance own classification.** *What is "sensitive," acceptable for AI, or must be blocked* is a compliance/records/legal determination. Implement their decisions; don't invent classification rules in the admin console.

• **Labels first, DLP second.** Sensitivity labels with **encryption/usage rights** are honored by Copilot at item level and travel with the content — they are the durable control. DLP-for-Copilot is the policy layer on top; where DLP-for-Copilot is unavailable, label encryption is the interim equivalent.

• **Keep the "keep out of AI" tier small and precise.** A tight, well-defined highly-confidential tier produces fewer false positives and cleaner enforcement than a broad, fuzzy one.

• **Tune, don't over-block.** An over-broad DLP-for-Copilot policy erodes trust in Copilot. Prefer precise label/sensitive-info-type conditions and iterate from the simulation data.

• **Prove the audit trail.** Confirm Copilot prompts/responses are recorded and eDiscoverable **before** you rely on the guardrails — the evidence path is part of the control, not an afterthought.

• **Re-measure on a cadence.** Content, labels, and Copilot usage drift. Run the read-only `Discovery → AuditSearch → Validate → Report chain monthly (Copilot Governance Review – Tenant – Recurring`) and treat new unlabeled-sensitive content Copilot can reach as a finding.

• **Verify preview/licensing before you commit.** DLP-for-Copilot and related capabilities are licensing-gated and some are in preview — confirm current availability in your tenant rather than assuming a blade or behavior.

• **Least-privilege the operator.** Use scoped Information Protection / DLP compliance roles and eDiscovery Manager; reserve Global Administrator for tenant-wide changes.

• **Keep the evidence.** Retain the coverage before/after, the simulation review, the audit-capture confirmation, and the governance report — the defensible record that Copilot use is governed.

Where to go next (adjacent catalog areas)

• **Copilot — Oversharing & SharePoint Permissions Remediation:** the access counterpart to this solution — fix *who can reach what* in SharePoint/OneDrive so Copilot honors the real boundary. Build it alongside this one; access + governance together are defense in depth.

• **Purview — Information Protection & Sensitivity Labels:** design and publish the label taxonomy, container labeling, and auto-labeling this solution enforces around Copilot.

• **Purview — Data Loss Prevention (endpoint/cloud/email):** the broader DLP program the Copilot-scoped policy sits within.

• **Purview — Audit (Standard/Premium) & eDiscovery:** deepen the investigation and retention capabilities

behind the Copilot audit trail.

- **Purview — DSPM for AI / Copilot Data-Protection Readiness:** exposure-insight and readiness views that

complement these guardrails.

- **Entra — Identity & Conditional Access:** harden the identity plane Copilot honors so governance is

enforced end to end.

8. Deliverables Summary — Microsoft 365 Copilot Data Governance & DLP Guardrails

Everything included in this solution, and how it is delivered.

Documentation (8 guides)

#	Document	Purpose
—	`executive-summary.md`	What it is, the outcome, the boundary, and the effort.
1	`01-solution-overview.md`	What it is, how Copilot honors labels/DLP, and the Assess → Configure → Pilot → Validate → Expand model; scope and connections.
2	`02-requirements.md`	Solution-specific prerequisites (Purview/DLP licensing, compliance roles, PowerShell, label taxonomy, auditing, pilot ring, stakeholders). Category prerequisites live in the global-requirements file.
3	`03-implementation.md`	Exact, ordered steps to discover coverage, apply labels/auto-labeling, configure DLP-for-Copilot and guardrails, audit, and enforce — every object named and reused, simulation-first.
5	`05-testing.md`	Pass/fail validation gates, including the audit-capture and simulation false-positive reviews.
6	`06-troubleshooting.md`	Symptom → cause → fix for the common failures.
7	`07-best-practices.md`	Keep-it-clean guidance and where to go next in the catalog.

#	Document	Purpose
8	`08-deliverables-summary.md`	This inventory.

> *Category-level prerequisites are published once in* `global-requirements-copilot.md` *and are not repeated in the per-solution docs.*

PowerShell scripts (5)

All scripts are white-label, store no secrets, and are **read-only by default**; the one script that creates enforcing policies defaults to `-WhatIf`**/simulation/test** and requires an explicit `-Commit`, gated behind a passed pilot.

Script	Purpose
`CPLTGOV-Discovery.ps1`	**Read-only.** Confirms connections/levers/Copilot-DLP-location/audit (`-ScopeOnly`), then reports published labels, sensitive info types, and label-coverage for the Copilot-accessible estate. Writes `Copilot Label Coverage – Estate – Assess`.
`CPLTGOV-Guardrails.ps1`	`-WhatIf`**/simulation/test by default;** `-Commit` **gated.** Creates the auto-labeling policy in **simulation** (`-Action AutoLabel`), the DLP-for-Copilot policy in **test/disabled** (`-Action DlpForCopilot`), and — only after the pilot gate — flips them to on/enforce (`-Action Enforce`). Never enforces silently.
`CPLTGOV-AuditSearch.ps1`	**Read-only.** Retrieves recent **Copilot interaction** audit events into `Copilot Interaction Audit – Tenant – Validate` and confirms the audit/eDiscovery evidence trail.
`CPLTGOV-Validate.ps1`	**Read-only.** Confirms the label policy is published, auto-labeling is in **simulation**, DLP-for-Copilot is in **test/disabled**, and auditing is on; writes a validation summary for the pilot gate.
`CPLTGOV-Report.ps1`	**Read-only.** Compiles the before/after `Copilot Governance Report – Tenant – Expand` — coverage, controls and their state, audit capture, and residual risk — for stakeholder sign-off.

How it is delivered

Delivered as a **Complete Solution Package (PDF + Word + scripts)** in a single ZIP (`CPLTGOV-Complete-Solution.zip`) — the eight guides as a formatted Word document and PDF, plus the five PowerShell scripts, yours to keep and reuse on every governance wave.

Boundaries recap

• **Classification determinations** (what is "sensitive," acceptable for AI, or must be blocked) are the compliance/records/legal decision — this package provides the technical controls and evidence.

• **DLP for Microsoft 365 Copilot** and related capabilities are licensing-/tenant-dependent and some are in preview — availability is flagged "verify," never assumed.

• The **sensitivity-label taxonomy and the broad DLP program** are built in the Purview information-protection / DLP solutions and are referenced, not rebuilt, here. **Access remediation** (SharePoint oversharing) is the companion Copilot solution.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

CPLTGOV-AuditSearch.ps1

CPLTGOV-Discovery.ps1

CPLTGOV-Guardrails.ps1

CPLTGOV-Report.ps1

CPLTGOV-Validate.ps1